

# Application Hardening

Applications are very popular, empowering users to finish assignments, make records, spreadsheets, databases, doing online examinations and sending emails, along with nearly every other task imaginable. Application software is always executed with the help of system software. Applications are some of the most troublesome parts of an IT base to secure due to their intricacy and the fact that they regularly need to acknowledge data from a mixed bag of clients, making application hardening an important fact of life for IT and security professionals.

All applications and programs introduced on system based host frameworks must be incorporated in the security solidifying procedure to guarantee that they don't give a feeble connection in the security protections. Various normal working framework based administrations are introduced as a matter of course. In order to make applications secure against system intrusions, application hardening must be used.

## What Is Application Hardening?

Application hardening involves various procedures to wipe out attacks on security by fixing vulnerabilities and killing inessential administrations.

The phrase application hardening is in reference to a variety of methods for protecting a computer system. Security is provided in layers, and is often referred to as "defense in depth". Layers of protection means protecting the host level, the level of application, operating systems, user level, physical level, and the various sublevels between each. Every level requires its own unique security method.

Computers with hardening are more secure systems. It can also be referred to as system hardening.

Hardening a system includes a few stages to shape layers of assurance. It ensures secure processing and protection layers to make systems secure inside and out. Hardening provides in depth and comprehensive defense..

Application hardening is becoming increasingly essential, in light of the mobile updates that have been sweeping the web. With the prevalence of mobile devices, cloud services, and social networks, a whole new batch of security challenges is facing the IT and security professional. Mobile devices make it easier than ever before to access both cloud services and social networks, presenting a serious challenge to IT. For utmost security, it is better to assume a mobile device is untrustworthy until proven innocent. Secure mobile apps can be built, with a higher level of security.

Hardening mitigate security risks and potential threats to system's vulnerability in following ways:

- Installing and using firewalls
- Creating system's backup
- Content filters are used
- Using the Security Configuration Wizard
- Introducing authentication and authorization processes to restrict access system, programs and applications
- Using data encryption techniques
- Establishing intrusion detection and prevention systems
- Closing server ports
- Disabling unnecessary user accounts, programs and cookies
- Installing and using suitable anti-virus, spyware, and malware detection and protection

- software
- Hardening proxies
- Using jailbreak detection systems

In order to maintain good system security and to prevent system collisions, application hardening is highly recommended.

## Application Patches:

Patches are usually updates for an application. A patch can contain few files with newer versions and executable which needs to be applied to an application. Patching an application can be done through any of the ways mentioned below.

### Installing the application in per user context

One recommended and easy approach is to install the entire application to a per user directory “local application data”. This allows a Standard User application to directly patch the files.

#### Pros/Cons

The main disadvantage to this approach however is when multiple users are using the same machine. This approach means that each user has a copy of the game installed, and patches will need to be re-downloaded per user. This will waste not only user's time and hard drive space, but also increase patch server bandwidth and because any application with standard user privileges can modify the application, it also doesn't protect the application's executables as well.

### Install to a common per machine location

Another method is to install just the non-executable data to a subdirectory in “Common Application data”. This is a shared location for all users and can be modified by Standard User applications.

#### Pros/Cons

This method minimizes the need to re-patch large files if the application is used from more than one account. It is recommended that the executables are kept in Programs Files to minimize the risk to other accounts on the system. The executables should verify the integrity of the new patch content in the shared directory since that can be modified by any Standard User application. This method has the advantage of working equally well on both Windows XP and Windows Vista, and doesn't require Administrator privileges.

### Acquire administrator privileges

The patch executable simply requires administrator privileges to run. With administrator privileges, the patch can directly modify the application files located in Program Files.

#### Pros/Cons

The advantage of this method is its simplicity. However this method is unsuitable if the application needs frequent patching because if someone with a Standard User account wanted to work on it that required frequent patching, then the user has two choices:

- Be inconvenienced by getting an administrator to login and patch the application, or
- Have their account permanently elevated with administrator privileges.

The latter one is not feasible as it weakens the security of the system as whole. Also when implementing this method, the patch executable must be different from the application executable. The patch executable should be marked with a manifest RunLevel tag of requiresAdministrator to denote it as an application that requires administrator privileges.

## Using Windows Installer for patching

This method is in par the best one when compared to all other techniques. Here, a Windows Installer is used to install the package (.msi file) and a Windows Installer patch (.msp file) would be distributed to install patches. The package must have an MsiPatchCertificate table and the patch must be digitally signed by a certificate in the table.

### Pros/Cons

The main advantage of this method is that patches can be applied with just a Standard User without requiring any elevation prompt. This provides a better user experience because the Standard User account doesn't have to ask an Administrator to install the patch or request permanent Administrator privileges to work on that particular application.

It is possible that this method may work in situations that need frequent patches, but the overhead of using Windows Install patch files in terms of build integration and supporting large numbers of files may make this method less desirable than others.

## Patches and Windows Installer

### Using UpgradeSync

Use UpgradeSync to find any potential errors or problems between a previous version and an upgraded version of your installation. To use UpgradeSync, make sure that you have access to the previous version of the .MSI. The previous .MSI is used by UpgradeSync to find inconsistencies from the old version to the updated one. Run UpgradeSync following the directions in the tool. For step-by-step directions on how to run UpgradeSync, see the topic titled "Using UpgradeSync" in the On-line Help.

When the comparison is finished, UpgradeSync displays a dialog box listing any problems in your installation. UpgradeSync automatically displays Microsoft's recommended changes to your current installation based on the type of upgrade you plan to make. These errors are the most common causes of patch and upgrade failures reported by Windows Installer users.

Any problems that UpgradeSync can fix are displayed with a checkbox. Mark the checkbox next to a problem, or click the Select All button, for UpgradeSync to fix them automatically. Any remaining problems that do not have checkboxes must be fixed manually. Select each of the errors individually to see the entire message in the Error Details box. Click Finish and UpgradeSync will correct the issues with the checkboxes and verify that the other issues have been fixed correctly.

You will need use UpgradeSync again to verify that the errors have been corrected. Once you have no problems listed in UpgradeSync, run the Patch Wizard to create a patch or use the Upgrade page to create an upgrade.

UpgradeSync lets you find and fix potential problems between versions of your installation before creating a patch or an upgrade. Not only does this save you time, it enables you to implement error-free patches and upgrades for your application.

UpgradeSync performs the following functions to prepare your current installation for patching or upgrading:

- It changes the PackageCode, ProductCode, and ProductVersion properties if necessary.
- It aligns component GUIDs.
- It detects errors that could cause problems with a patch or upgrade and, if possible, fixes them.

## **Active Directory:**

### **What does Active Directory (AD) mean?**

Active Directory (AD) is a Windows OS directory service that facilitates working with interconnected, complex and different network resources in a unified manner.

Active Directory was initially released with Windows 2000 Server and revised with additional features in Windows Server 2008. Active Directory provides a common interface for organizing and maintaining information related to resources connected to a variety of network directories. The directories may be systems-based (like Windows OS), application-specific or network resources, like printers. Active Directory serves as a single data store for quick data access to all users and controls access for users based on the directory's security policy.

Active Directory provides the following network services:

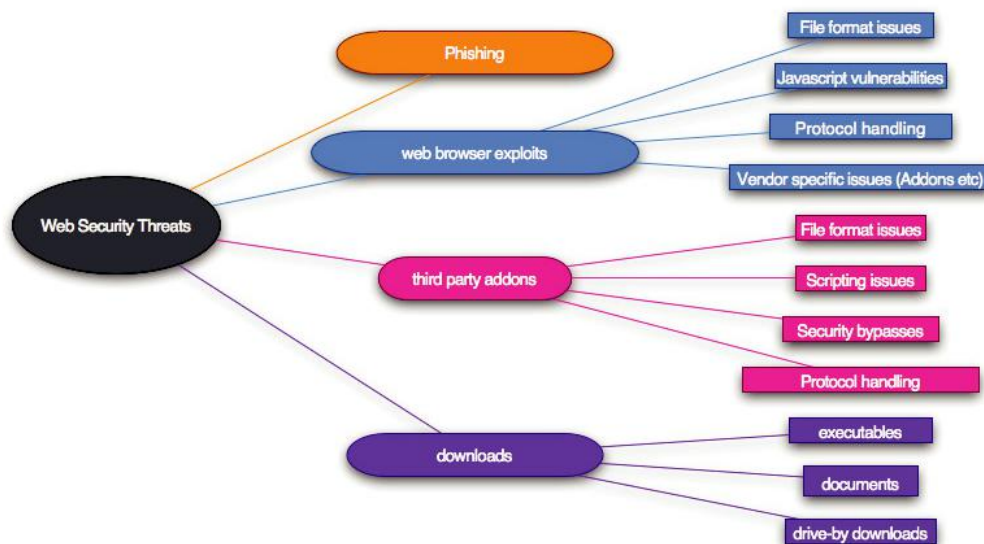
- Lightweight Directory Access Protocol (LDAP) – An open standard used to access other directory services
- Security service using the principles of Secure Sockets Layer (SSL) and Kerberos-based authentication
- Hierarchical and internal storage of organizational data in a centralized location for faster access and better network administration
- Data availability in multiple servers with concurrent updates to provide better scalability

Active Directory is internally structured with a hierarchical framework. Each node in the tree-like structure is referred to as an object and associated with a network resource, such as a user or service. Like the database topic schema concept, the Active Directory schema is used to specify attribute and type for a defined Active Directory object, which facilitates searching for connected network resources based on assigned attributes. For example, if a user needs to use a printer with color printing capability, the object attribute may be set with a suitable keyword, so that it is easier to search the entire network and identify the object's location based on that keyword.

A domain consists of objects stored in a specific security boundary and interconnected in a tree-like structure. A single domain may have multiple servers – each of which is capable of storing multiple objects. In this case, organizational data is stored in multiple locations, so a domain may have multiple sites for a single domain. Each site may have multiple domain controllers for backup and scalability reasons. Multiple domains may be connected to form a Domain Tree, which shares a common schema, configuration and global catalog (used for searching across domains). A Forest is formed by a set of multiple and trusted domain trees and forms the uppermost layer of the Active Directory. Novell's directory service, an Active Directory alternative, contains all server data within the directory itself, unlike Active Directory.

## Web threats

It is not so hard to fall victim to a user account or system compromise introduced through the web. But what are the various issues involved?



3

### Phishing

One of the less advanced, but nonetheless effective threats is phishing. The term refers to attacks where the victim is led to believe that he or she is on a legitimate website, when in fact it is just a copy of the real one. This attack relies on the fact that anyone can create their own website and any website can look like any other. A real world example would be a fake ATM that is put in the middle of a busy shopping center. There would be very few signs to show victims that it is not a real ATM – until no money comes out. Similarly, in a phishing attack victims may think that they are on their bank's website, and therefore do not think twice about using pin numbers as requested. This attack is not limited to banking systems.

Phishing attacks have been known to target company email websites (webmail), public email websites (like Gmail) and popular sites like Amazon or eBay.

Users can identify a phishing website in a number of ways. The first is to look at the URL. Another effective prevention technique is to never follow links by email but to type them in or use bookmarks. Although not foolproof, these methods make it harder for attackers to pull off the scam.

## Web browser exploits

Cybercriminals have also set up websites that exploit security holes in the web browser. This technique allows them to gain access without the victim's knowledge. Web browsers are complex software. They have to handle various file formats, such as images, sound and HTML, Javascript and a multitude of other technologies. All of these features add to the attack surface of the web browser, thus making the technology relatively weak from a security standpoint. Yet this same functionality is what makes it so useful.

Not surprisingly, both Internet Explorer and Firefox have had their fair share of security vulnerabilities. In fact, as of 2009, Secunia estimates that Internet Explorer 7 had over 90 vulnerabilities, while Firefox 3.0 had over 130 vulnerabilities. Some of these security flaws could be exploited to allow individuals to remotely compromise that user account. This typically means that a successful attacker who exploits the web browser gets access to private emails, sensitive documents and anything else that the user running the web browser has access to.

## Third party add-ons

The majority of websites require the use of third party add-ons such as Adobe Flash player and Acrobat Reader. Both of these widely used products have become a favorite target for cybercriminals. As more administrators and home users update their machines with the latest security updates and patches for their browsers, as well as the ability to automate the process, it becomes harder to use web browsers as an attack vector.

However, although they may be updating their browser software, it is also true that many people forget to update third party add-ons like the Flash player. In 2009 a number of malware "in the wild" (out there on the Internet) have exploited the PDF file format, Adobe Acrobat, Flash, a number of ActiveX components and Java. These third party add-ons are used to push users to other websites that have been compromised

## Downloads

While automating remote code execution is very attractive for attackers, there are many times when this level of sophistication is not required to compromise end-users' computers. In fact, some attacks still rely on end-users downloading executable files. To aid attackers, legitimate websites, some of which are high profile, are being compromised. As soon as these sites become infected, they can start serving malware, thus exploiting a user's tendency to trust content based on reputation. When a legitimate news site asks end-users to download an executable file (e.g., codec) to view an intriguing video, many will comply because they trust that website.

Malware creators use a variety of techniques to convince users to visit poisoned sites, search results and download executables.

The bad guys love to play on two characteristics of human nature: fear and curiosity. In 2009, the rise of 'scareware' has been considerable. Playing on people's fears that their machine has been infected with malware, users are encouraged to download antivirus software. This is nothing but malware that infects the machine and demands payment if the user wants to uninstall the software.

Another threat is the use of poisoned search engine results. The bad guys create numerous websites for well known keywords and use these sites to feature high upon on web searches. When a user searches for a particular name or subject and clicks on a poisoned link, he or she is taken to a fake website where they are told to either download software to continue or else malware is downloaded while they are looking at the content.

## Hybrid attack

While the web offers much greater scope for attackers, email still remains a powerful tool. Combined with the web, the threats not only multiply but the risk that the user becomes a willing prey is very high. One common trick is to use current news events to spread malware spam. Emails purporting to offer exclusive news, videos or files are popular online traps to open dangerous attachments or be redirected to infected or fake websites.

### *What do these web threats lead to?*

Malware infections cause a number of problems. Machines become unresponsive or sluggish resulting in users becoming frustrated and administrators spending precious time trying to find the problem. When a machine is infected, some administrators often want to simply re-install the operating system, however a responsible system administrator or security analyst would want to investigate and assess the situation before doing anything else. All of these tasks take time and resources. People have to stop working, the hardware has to be replaced and so on. Additionally, some malware creates a denial of service by design, increasing the possibility of an attack on the organization's infrastructure.

While most organizations understand denial of service very well – since it impacts productivity – many ignore the impact on confidentiality and integrity. Attackers are known to harvest sensitive information from compromised computers to carry out further and deeper attacks within the network. If they access the organization's data they can use this to sell to third parties and make a profit. Modern malware can create an automated process to harvest information from a network that has been breached.

Once an attacker is on the inside, his or her work is significantly easier since on most networks, systems on the inside are trusted. This is what makes attacking web visitors through infected websites so attractive to the bad guys. End-users and their web browsers are already on the internal network. Unlike traditional network-based attacks, the victim connects to the attacker instead of the other way round. Even today, most defenses are still focused on preventing attackers from trying to connect to the victim, i.e., protecting the perimeter.

### *What needs to be done*

Prevention is certainly better than having to clean up after a security breach or web-based attack. Attacks often depend on the end-user making a mistake and clicking on attachments or links. That is why security awareness and education play an important part in the overall security of an organization's network.

If end-users are aware of the threats, understand how their actions could be a contributing factor and have clear steps to follow if they see something suspicious, then the chances are that security will improve.

## Security policies

Education alone is not enough. Organizations need security and user policies that can be enforced. These policies need to be reasonable and allow employees to do their job yet limiting actions that could be a security risk. This is easier said than done because many security policies and solutions impact usability. Therefore a good security analyst has a tough job finding a balance between security and helping employees to deliver and be productive. When policies are too strong, employees will find ways around the policies or become less productive – a situation that is untenable and unacceptable for a business.

Security policies are important but only effective when they are enforced and users are aware of them. It is highly recommended that businesses create acceptable user policies that every employee has to sign. Enforcement, however, is another story and requires more than just an employee's signature on a piece of paper that they will probably never see again. Technology is key here because it allows administrators to enforce policies across the network with minimal effort.

## Using technology

Although administrators are comfortable working with technology, they are somewhat limited in dealing with human nature. Policies and education are important but you will still find people who don't really care. If they want to open a file or click on a link they will do so. So administrators need to boost their arsenal with technology.

Anti-spam and anti-phishing software, for example, will reduce the volume of unwanted email reaching the end-user, thereby reducing the risk of exposure to phishing scams and redirects in email. An administrator cannot (and should not) depend on end-users to follow policies to the letter.

Bandwidth monitoring is one of the basic methods used to detect unwanted web traffic. If, on average, an employee only browses a few websites every day, but this behaviour changes drastically, the administrator needs to look into the matter. The employees may have changed his or her browsing habits but it may also be a sign that the machine has been compromised. Bandwidth monitoring is an important tool for network and security administrators.

## Content filtering

While bandwidth monitoring gives an overall view of what is happening, it does not provide an in-depth analysis. Content filtering solutions for the web allow administrators to choose web content by file type and by location. Since certain file types available on the web are used more often by the bad guys, content filtering by file type is a very effective way to protect web browsers without impacting negatively on usability. This type of solution, for example, could be used to block web content that may execute on the client, such as exe files or installation files (MSI).

Content filtering does not solve all security problems associated with web clients. In fact, malicious attackers make use of file types or web locations that are more often than not also used for legitimate purposes. For example, HTML does not typically include any malicious content. By embedding exploit code in HTML files, attackers typically bypass most content filtering that relies on blocking specific file types. Therefore having an antivirus solution – preferably deploying multiple antivirus engines – is still very effective, especially if that antivirus solution is good at catching this type of malicious content. Implementing an antivirus solution at a

strategic point such as a web gateway or proxy has various advantages. It can be centrally managed and is separate from the end-user's computer that may be already infected.

Prevention is only part of a holistic solution that should be in place to counter web-based threats. Regular monitoring and auditing will help detect security incidents that may have occurred. One reason why some security incidents are more serious than they should be is that these incidents are not handled correctly. In the case of web threats, an incident response plan typically covers things like roles and responsibilities as well as procedures on how to respond to incidents with guidelines on preparation, identification, containment and recovery.

